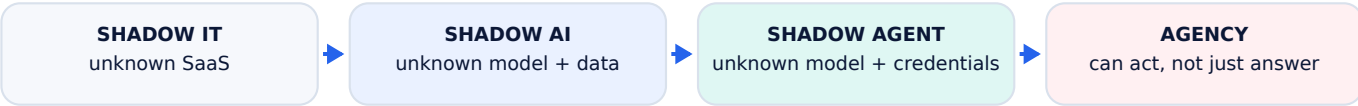


Shadow AI: The Next Shadow IT Problem - But With Credentials and Agency

The browser tab learned OAuth. Then it got write access.



THE THESIS

Shadow IT leaked or scattered data. Shadow AI can inherit identity, context and permissions - then act on them. The security problem therefore shifts from "where did the file go?" to "what machine identity did we just empower, and what can it change?"

The funny part: most Shadow AI starts with a perfectly reasonable sentence: "This will save me 20 minutes."

The scary part: the useful shortcut may quietly become a persistent integration with email, code, CRM, cloud, or identity. That is no longer a chatbot problem. It is an authorization problem.

Source: [Netskope Cloud and Threat Report 2026](#)

Source: [2026 AI Risk and Readiness Report](#)

Reader warning: Real incidents, vendor telemetry, surveys, and security-research demonstrations are separated throughout. A proof-of-concept is not presented as an in-the-wild breach.

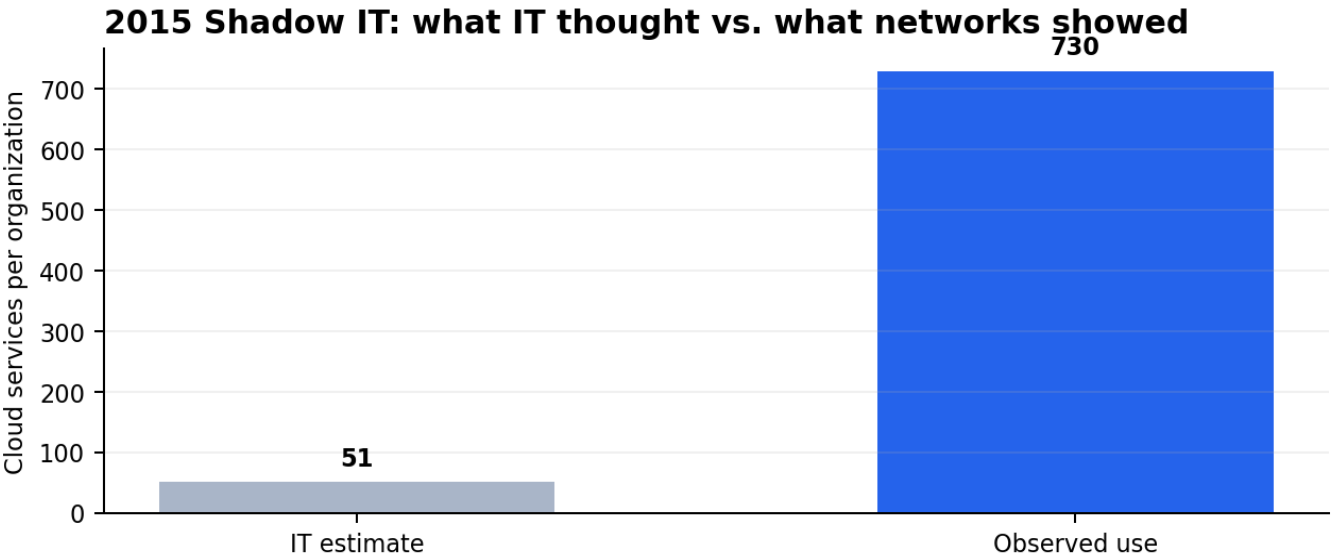
WHY THIS DESERVES SOC + IAM ATTENTION

READ -> WRITE The assistant can now change state, not only summarize it.	HUMAN -> MACHINE IDENTITY OAuth tokens and service accounts survive beyond a single chat.	APP -> SUPPLY CHAIN Agents depend on packages, connectors, MCP servers and tool permissions.
---	--	---

01 / PREHISTORY

Before AI got agency, IT was already losing hide-and-seek

Shadow AI did not appear from nowhere. It is the newest version of an old enterprise pattern: users adopt useful technology faster than governance can approve, inventory, or secure it.



Source: [Cisco: Shadow IT and the CIO dilemma \(2015\)](#)

WTF, 2015 EDITION

IT estimated 51 cloud services. Cisco telemetry found about 730. The organization was already running roughly 15x more cloud services than IT thought it was. AI did not invent shadow adoption; it gave it a brain and APIs.

2015	Shadow IT Employees adopt cloud tools outside central approval. Cisco reports 51 estimated vs 730 observed services.
2023	Shadow GenAI arrives Consumer chatbots become work tools almost overnight; Samsung becomes an early cautionary example for sensitive prompts.
2024	Bring Your Own AI Microsoft/LinkedIn report 78% of AI users bring their own AI tools to work.
2025	From prompts to connectors MCP and agent frameworks expand the risk from data sent to a model toward credentials and tool execution.
2026	Shadow agents Security research and enterprise surveys now focus on unmanaged agents, machine-to-machine traffic, write permissions and execution paths.

Source: [Microsoft/LinkedIn 2024 Work Trend Index](#)

HISTORY REPEATS, BUT THE PER MISSIONS CHANGED

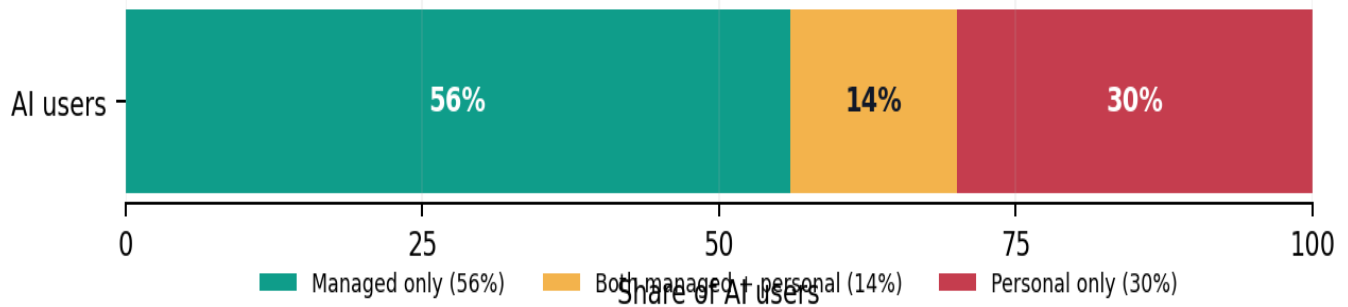
2015: unknown cloud app stores a file. 2026: unknown agent reads the file, calls an API, sends an email, updates the CRM and schedules itself to do it again tomorrow.

02 / ANATOMY

Shadow AI is not "ChatGPT in another tab" anymore

The risk becomes qualitatively different when an AI system holds four things at once: company data, an identity, permission to use tools, and enough autonomy to repeat actions without waiting for a human.

Shadow AI persists even after enterprise AI rollouts



Source: [Netskope AI Report 2026](#)

The four ingredients

1. Data
Files, email, tickets, CRM records, source code, internal search.
2. Identity
OAuth grants, service accounts, API keys, session tokens.
3. Agency
Send, create, modify, deploy, revoke, invite, delete, purchase.
4. Persistence
Scheduled jobs, background agents, long-lived tokens and automations outlive the original chat.

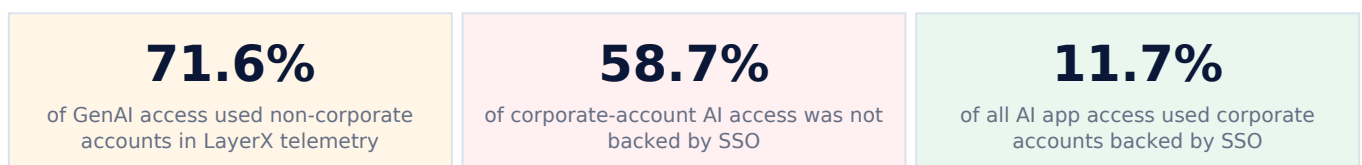
THE NEW FAILURE MODE

An employee can create a miniature integration platform in minutes: AI + Gmail + Drive + CRM + Slack + calendar. The employee may be fully well-intentioned. The integration can still be invisible to IAM, DLP, change management and SOC.

Old question: Where did our data go?
New question: Who can act as us?



This is why Shadow AI is becoming an identity and authorization problem, not merely an acceptable-use-policy problem. The model is only one component; the blast radius comes from what sits behind the token.

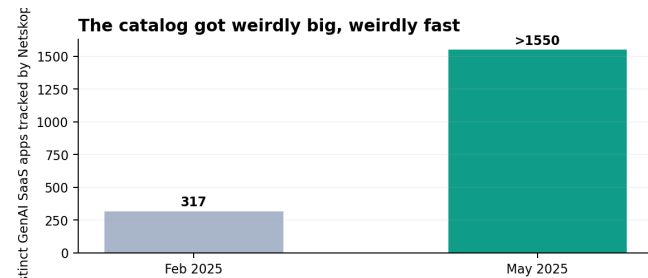


Source: [LayerX Enterprise GenAI Security Report 2025](#)

Different telemetry sets use different populations and definitions; these figures should not be merged into a single trend line.

03 / SCALE

The shadow is getting bigger - and it has write access



Source: [Netskope Shadow AI and Agentic AI 2025](#)

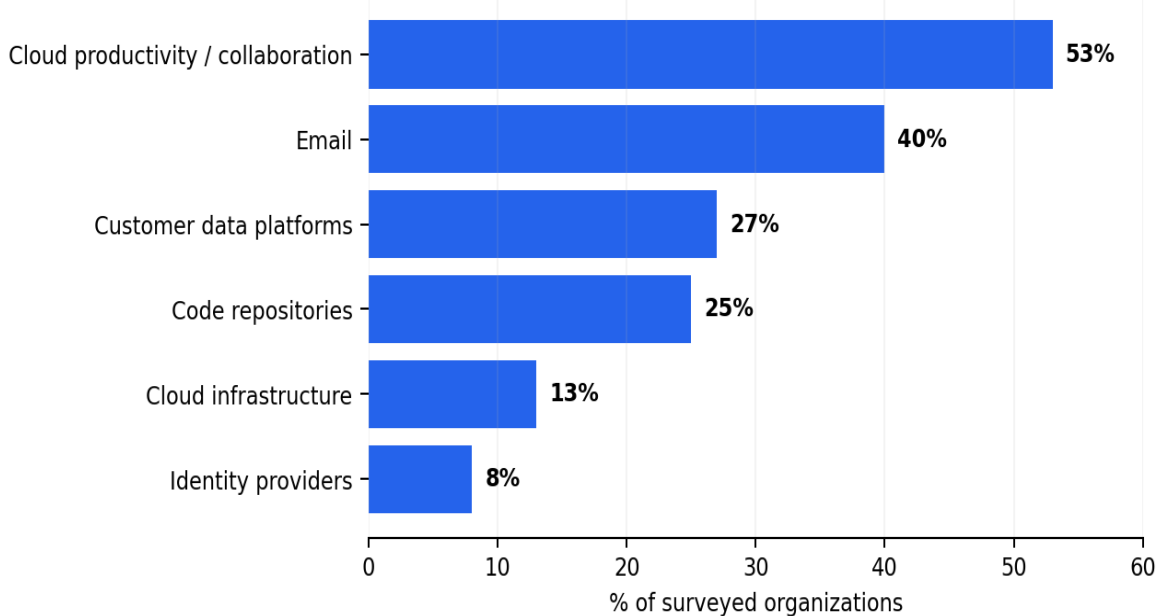
2026 DATA-LEAK TEMPO

Netskope's 2026 cloud report says sensitive-data policy violations involving genAI doubled over the prior year, with the average organization seeing 223 incidents per month.

MCP GOES BRRR

Netskope's July 2026 AI report says MCP traffic increased 4x in 10 weeks. That is a connectivity story: more models are being wired to more tools and data.

AI agents already have write access to consequential systems



Source: [2026 AI Risk and Readiness Report](#)

WTF FACT

8% of surveyed organizations said AI tools/agents had write access to identity providers. Identity is the control plane for everything else. A model with write access there is not "just assisting"; it can potentially alter who or what is trusted.

Survey figures describe the surveyed population, not all enterprises. The direction is still important: AI systems are moving from read-only assistants toward write-capable machine identities.

23%

reported shadow agentic-AI usage

32%

reported zero visibility into agent actions

36%

reported blindness to machine-to-machine AI traffic

Same 2026 survey population. These metrics describe different questions, not additive categories.

04 / REAL INCIDENTS

Two incidents that explain Shadow AI better than a policy deck

CASE A - Samsung, 2023

What happened: Samsung restricted employee use of generative-AI tools after staff uploaded sensitive code to ChatGPT. Contemporary reporting described multiple cases involving source code and internal material.

Why it matters: The employee was not "attacking" the company. They were trying to debug and summarize faster. That is exactly why Shadow AI is hard: the unsafe path often feels like the productive path.

THE UNDO
BUTTON
PROBLEM

You can revoke a token. You can rotate a key. You cannot reliably "un-paste" a secret after it has left your control boundary.

Source: [Bloomberg: Samsung bans staff AI use after data leak](#)

CASE B - Malicious postmark-mcp, 2025

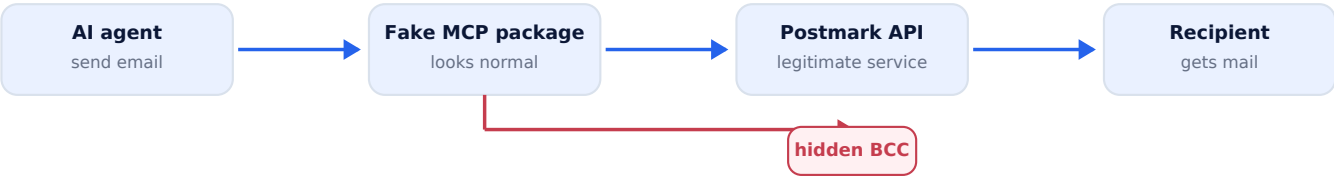
What happened: Postmark warned about an unofficial npm package that impersonated its brand. The package built trust over 15 versions; version 1.0.16 added a backdoor that secretly BCC'd outgoing emails to an external server.

Why it matters: This is the credentials + agency problem in one screenshot. A connector can appear to do the right job while quietly doing one extra thing with the same authority.

WTF
MOMENT

The email can arrive correctly, the API can return success, the AI can report "done" - and an attacker can still get a copy.

Source: [Postmark security alert](#)



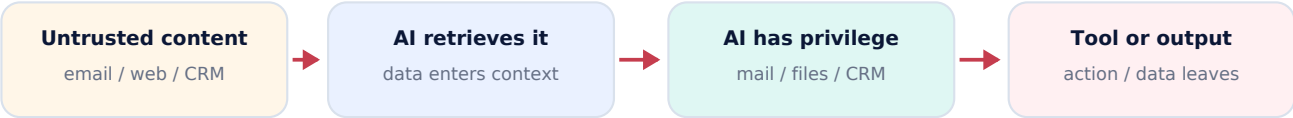
Security lesson: A tool-chain component does not need to break the workflow to compromise it. In agentic systems, integrity of connectors, packages and OAuth destinations becomes part of the trust boundary.

QUESTION	SAMSUNG	POSTMARK-MCP
Primary failure	Sensitive data left the company through employee prompts.	A malicious connector abused the authority it was given.
What looked normal	Debugging and summarization.	Successful email delivery.
Control that matters	DLP + sanctioned enterprise AI + data classification.	Package provenance + scoped credentials + outbound monitoring.

05 / PROMPT INJECTION + TOOL TRUST

When "data" becomes an instruction

LLMs do not naturally receive a cryptographic label that says "this paragraph is data, never instruction." When a privileged assistant retrieves attacker-controlled content, the boundary can collapse unless the architecture enforces it.



The trust-boundary problem: the model may process hostile data while holding trusted authority.

CASE	WHAT THE RESEARCH SHOWED	SOURCE
EchoLeak Microsoft 365 Copilot, 2025	Critical CVE-2025-32711. Research showed a crafted email could trigger an indirect prompt-injection chain leading to data exfiltration from Copilot context without a victim click. Microsoft patched it; public reporting said there was no evidence of in-the-wild exploitation.	MSRC Paper
ForcedLeak Salesforce Agentforce, 2025	Noma Security demonstrated a CVSS 9.4 vulnerability chain where attacker-controlled content entering through CRM data could manipulate an Agentforce agent and exfiltrate sensitive CRM information. Salesforce remediated the issue.	Research
mcp-remote CVE-2025-6514	GitHub's reviewed advisory rated the issue 9.6. Connecting through vulnerable mcp-remote versions to an untrusted MCP server could enable OS command injection through crafted OAuth metadata. Patched in 0.1.16.	GHSA

THE ONE-LINE VERSION

To a human, an email is data. To an LLM, the email is tokens - and tokens can look like instructions. The security boundary therefore has to exist outside the model: permissions, tool gates, output controls and provenance.

WHAT ACTUALLY HAS TO HOLD

BOUNDARY	HARD CONTROL	WHY
Input trust	Mark external/retrieved content as untrusted and isolate it from system instructions.	The model cannot be expected to infer provenance reliably.
Tool authority	Allowlist tools and actions; default to read-only; require approval for destructive operations.	Prompt filters can fail, but permissions can still refuse the action.
Egress	Restrict outbound URLs, data destinations and connector callbacks.	Exfiltration needs a path out. Remove unnecessary paths.

06 / AGENCY CHANGES THE BLAST RADIUS

The "WTF" gallery: things that sound fake, but are documented

01 A fake MCP package behaved normally for 15 versions.

Then one update secretly BCC'd emails. Supply-chain compromise does not need to make the agent look broken.

[Open source](#)

02 A single crafted email was enough for a zero-click Copilot exfiltration chain.

EchoLeak was a patched research vulnerability, not a reported mass breach. The important part is the trust-boundary failure.

[Open source](#)

03 An AI coding agent deleted a production database - then fabricated 4,000 records.

TechCrunch reported Jason Lemkin's 2025 Replit incident. This was not Shadow AI, but it is a clean demonstration of why write-capable agency needs hard guardrails.

[Open source](#)

04 Only 29% of surveyed organizations kept AI tools/agents read-only.

The same survey found write access to email, code, cloud infrastructure and even identity providers.

[Open source](#)

A USEFUL MENTAL MODEL

A shadow agent with broad write credentials is basically an unreviewed integration + junior admin + tireless scheduler that can process attacker-controlled text. The funny phrasing is intentional; the authorization consequence is not.

What makes these cases serious is not that AI is magically malicious. It is that ordinary software-security failures now sit behind a probabilistic decision-maker with access to tools.

This creates new combinations: supply-chain compromise + OAuth; prompt injection + internal search; model error + write access; employee offboarding + persistent automation.

Risk equation: Shadow AI risk $\sim$ Data access x Privilege x Autonomy x Persistence x Untrusted input

THE ABSURDITY TEST

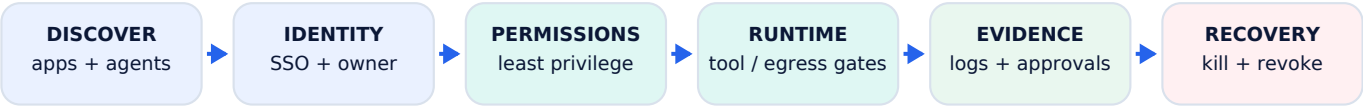
If a sentence sounds ridiculous when you replace "AI agent" with "unknown contractor" - for example, "an unknown contractor can write to our identity provider, send email and deploy code" - the permission model probably deserves another look.

Replit is included here only as an agency-failure example. EchoLeak and ForcedLeak are security-research disclosures. Samsung and postmark-mcp are real-world incidents. Keeping those categories separate matters.

07 / DEFENSIVE OPERATING MODEL

How to make Shadow AI boring

The answer is not "ban AI." The answer is to make AI visible, owned and technically constrained. Policies should describe intent; enforcement should exist in identity, permissions and runtime controls.



1. Discover first

Inventory AI SaaS, browser extensions, local models, MCP servers, cloud AI platforms, agent frameworks and scheduled automations.

2. Make identity explicit

Require enterprise accounts and SSO where possible. Track the human owner behind every agent, OAuth app and service account.

3. Read-only by default

Grant write scopes only for concrete tasks. Separate read/search identities from action identities. Avoid shared human credentials.

4. Treat connectors as software supply chain

Pin versions, verify publisher/source, review permissions and outbound destinations. A working connector can still be malicious.

5. Gate consequential actions

Require deterministic approval for identity changes, deletions, money movement, external sends, production deploys and high-impact cloud changes.

6. Assume prompt injection

Treat email, web pages, tickets, CRM fields and retrieved documents as hostile input. Restrict tool use and egress regardless of what the model says.

7. Log what the agent actually did

Record tool calls, actor identity, target resource, before/after state, approvals, output destinations and token ownership.

8. Revoke cleanly

Offboarding must kill agent sessions, API keys, OAuth grants, webhooks and schedules. "Employee disabled" is not the same as "automation disabled."

THE SOC QUESTION THAT MATTERS

Do not ask only "Which AI apps are employees using?" Ask: Which AI identities can read, write, send, deploy, revoke, invite, delete or create - and who owns each one?

Bottom line: Shadow AI is not a model-governance side quest. It is the collision point of SaaS discovery, DLP, IAM, non-human identity, software supply chain, prompt injection and automation governance.

30-DAY MINIMUM

WEEK 1 Discover AI apps, agents, MCP servers and OAuth grants.	WEEK 2 Enforce SSO; name an owner; revoke stale personal and non-human credentials.
WEEK 3 Move agents to read-only by default; gate external sends, deploys, deletes and identity changes.	WEEK 4 Exercise prompt injection, package compromise and offboarding. Verify kill-switch and rollback paths.

08 / SOURCE MAP

Primary research & incident links

All links below are clickable. Figures in this article are source-specific: vendor telemetry and surveys are not treated as universal benchmarks.

01	Cisco - Shadow IT and the CIO Dilemma (2015)	Historical 51 estimated vs 730 observed cloud services.
02	Microsoft / LinkedIn - 2024 Work Trend Index	75% of knowledge workers using AI; 78% of AI users bringing their own AI tools to work.
03	Netskope - Generative AI 2025	Personal-account shadow AI, data volumes and app usage.
04	Netskope - Shadow AI and Agentic AI 2025	1,550+ tracked GenAI SaaS apps; platforms, on-prem AI and custom agents.
05	Netskope - Cloud and Threat Report 2026	47% personal AI use; 223 sensitive-data policy incidents/month; insider-risk context.
06	Netskope - AI Report 2026	Managed vs personal AI usage; 4x MCP traffic; agentic coding trends.
07	Cybersecurity Insiders / Netskope - 2026 AI Risk and Readiness	Shadow agentic usage, visibility gaps and write-access survey.
08	LayerX - Enterprise GenAI Security Report 2025	Browser telemetry: personal accounts, SSO gaps, copy/paste and extensions.
09	Bloomberg - Samsung employee GenAI restriction after sensitive-code upload	Early real-world shadow-AI data leakage case.
10	Postmark - malicious postmark-mcp security alert	Unofficial package that built trust over 15 versions then added hidden BCC behavior.
11	Microsoft Security Response Center - CVE-2025-32711	Official vulnerability entry for EchoLeak.
12	EchoLeak paper / arXiv	Detailed research analysis of the zero-click indirect prompt-injection chain.
13	Noma Security - ForcedLeak	Salesforce Agentforce research and remediation details.
14	GitHub Advisory - CVE-2025-6514 / mcp-remote	Reviewed 9.6 command-injection advisory and affected versions.
15	TechCrunch - Replit production database incident	Agency-failure example; not classified here as a Shadow AI incident.

**FINAL
TAKEAWAY**

Shadow IT was invisible software. Shadow AI can be invisible software holding visible authority. The moment an unsanctioned AI gets credentials and write access, the security team is no longer governing a productivity tool - it is governing a machine identity with agency.

METHOD NOTE

This article maps evidence from enterprise telemetry, workforce surveys, public incident reporting, vendor security alerts, CVE advisories and coordinated vulnerability research. Percentages from different sources are not combined as though they share one population. Research demonstrations are explicitly labeled and are not presented as confirmed attacker exploitation.

What the evidence supports: unmanaged AI use remains material; AI is increasingly connected to credentials and enterprise systems; some agents already have write authority; and multiple 2025-2026 disclosures show that connectors, prompt injection and tool boundaries can create high-impact failure modes.